

MAPEO DETALLADO — PREGUNTAS ↔ REQUISITOS NORMATIVOS

Trazabilidad Completa Encuesta a Regulaciones

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Público

INTRODUCCIÓN

Tabla de trazabilidad que vincula cada pregunta encuesta a:

- Artículos/Secciones normativos específicos
- Requisitos técnicos concretos
- Evidencia de cumplimiento

Propósito: Facilitar auditoría; demostrar que encuesta es "audit-ready"

SECCIÓN 1: GOBERNANZA

Pregunta	Regulación	Artículo/ Requerimiento	Objetivo Medición	Evidencia Compliance
1.1.1 RAS documentado	DORA	Art 11 Risk Management Framework	¿Risk appetite formally defined?	RAS document, board approval memo, annual review
	NIS2	Art 17 Security requirements	Governance structures	-
	NIST CSF 2.0	Govern.RM-2 Risk Appetite	Strategic risk alignment	-
	ISO 27001	Clause 5.1 Leadership commitment	Board tone at top	-
1.1.2 Risk Tolerance umbrales	DORA	Art 11 Risk assessment	Operational thresholds	Risk Tolerance Statement, escalation procedures
	NIS2	Art 17 Compliance	Documented limits	-
	COSO Framework	Risk Assessment component	Control triggers	-
1.1.3 Junta oversight	DORA	Art 11 Board role	Executive accountability	Meeting minutes, quarterly reports, audit trails
	NIS2	Art 18 Governance	Senior management	-
	NIST CSF 2.0	Govern.OC-3 Stakeholder communication	Board visibility	-
1.2.1 NIST CSF 2.0 mapeo	NIST CSF 2.0	Govern function	Framework adoption	Assessment report, gap analysis
	NIS2	Art 13 Security measures	NIST alignment	-
1.2.2 CISO designado	DORA	Art 11 CISO role	Formal designation	Job description, reporting line, compensation
	NIS2	Art 18 Designación responsable	Accountability	-
	NIST CSF 2.0	Govern.OC-1 Leadership	Chief role	-

SECCIÓN 2: CUANTIFICACIÓN (FAIR)

Pregunta	Regulación	Artículo	Objetivo	Evidencia
2.1.1 FAIR adoption	DORA	Art 15 ICT Risk Assessment	Risk quantification	FAIR methodology document, ALE calculations
	CNMV (España)	Circular 3/2020	Financial sector recommendation	-
	FAIR Institute	Standard	Framework certification	Training certificates
2.1.2 Top 5 risks ALE	DORA	Art 15 Risk measurement	Quantified impact	Risk register with ALE estimates
	NIS2	Art 13 Risk assessment	Documentation	Updated annually
	ISO 27001	Clause 8.2 Risk evaluation	Monetary impact	Annexed to ISMS
2.1.3 ROI analysis	SOX (si aplicable)	Sect 404 Control effectiveness	Investment justification	Business cases, ROI spreadsheets
	DORA	Art 16 Control decisions	Prioritization	-
	FAIR Institute	Principle	Standard practice	-

SECCIÓN 3: THREAT MODELING (PASTA)

Pregunta	Regulación	Artículo	Objetivo	Evidencia
3.1.1 Threat modeling formal	NIST CSF 2.0	Identify.RA-1 Threat analysis	Risk identification	PASTA documentation, threat registers
	ISO 27001	Clause 8.2 Risk assessment methodology	Systematic approach	Assessment templates
	PASTA Framework	Standard	Industry practice	Threat modeling reports
3.1.2 Attack trees	NIST SP 800-30	Threat likelihood	Scenario modeling	Attack tree diagrams, PoC evidence
	PASTA Framework	Stages 6-7	Attack simulation	-
3.1.3 Threat-vuln mapping	NIST CSF 2.0	Identify.RA-3 Vulnerabilities	Threat correlation	Correlation matrix, CAPEC-to-CWE mappings
	ISO 27001	Clause 8.2	Weakness identification	-

SECCIÓN 4: MÉTRICAS SOC

Pregunta	Regulación	Artículo	Objetivo	Evidencia
4.1.1 SOC 24/7	DORA	Art 19 Incident Response	Continuous monitoring	SOC hours log, staffing matrix
	NIS2	Art 19 Incident response	Detection capability	-
	NIST CSF 2.0	Detect	Continuous monitoring	-
4.1.2 MTTD <30 min	DORA	Art 19 Detection	Fast detection	Alert logs, SIEM data, timestamps
	NIST CSF 2.0	Detect.DE-1	Threat detection	-
	MTTD Benchmark	Industry standard	Performance metric	-
4.1.3 MTTR <4h crítico	DORA	Art 19 Response	Fast containment	Incident logs, RTO achievement
	NIST CSF 2.0	Respond	Incident response	-
4.2.1-4.2.4 SIEM	DORA	Art 28 ICT Monitoring	Log collection	SIEM architecture diagram, ingestion rates
	NIS2	Art 13 Security measures	Event management	-
	NIST CSF 2.0	Detect.DE-2	Security monitoring	-

SECCIÓN 5: VULNERABILITIES

Pregunta	Regulación	Artículo	Objetivo	Evidencia
5.1.1 Scanning continuo	NIST CSF 2.0	Identify.RA-2	Vulnerability discovery	Scan schedules, asset reports
	ISO 27001	Clause 8.2	Risk assessment	-
	NIS2	Art 13	Security measures	-
5.1.2 Patch SLA <7d críticos	DORA	Art 13 Vulnerability management	Timely remediation	Patch logs with timestamps
	ISO 27001	Clause 8.3	Patch management	SLA documentation
	NIS2	Art 13	Appropriate measures	-
5.1.3 CVSS v4.0	NIST NVD	Standard 2024	Current scoring	Vulnerability reports
	NIST CSF 2.0	Identify.RA-1	Severity assessment	-

SECCIÓN 6: SUPPLY CHAIN

Pregunta	Regulación	Artículo	Objetivo	Evidencia
6.1.1 Vendor audit anual	DORA	Art 29 Third-party risk	Audit verification	Audit reports, SOC2, ISO 27001 certs
	NIS2	Art 17 Supply chain	Third-party assessment	-
	ISO 27001	Clause 8.3	Supplier controls	Contracts, audit records
6.1.2 Contractual security	DORA	Art 29 Contractual requirements	SLA enforcement	Contracts with security clauses
	GDPR	Art 28 Data processor	Binding contract	-
	NIS2	GV.SC Supply chain	Contractual requirements	-
6.1.3 SBOM	EU CRA	Cyber Resilience Act	Software transparency	SBOM files (SPDX format)
	US EO 14028	Software supply chain	Artifact transparency	-
	NIS2 (proposed)	Supply chain	Dependencies	-

SECCIÓN 7: AWARENESS TRAINING

Pregunta	Regulación	Artículo	Objetivo	Evidencia
7.1.1 Training obligatorio 100%	GDPR	Art 32 Awareness	Security awareness	Training records, completion rates
	ISO 27001	Clause 7.3 Personnel awareness	Mandatory training	-
	DORA	Art 12 Competence	Personnel training	-
7.1.2 Phishing simulations monthly	NIS2	Art 13 Security measures	Resilience testing	Simulation reports, click rates
	NIST CSF 2.0	Govern.OC-2 Awareness	Security culture	-
7.1.3 Phishing click rate <5%	KnowBe4 Benchmark	Industry standard	Effectiveness metric	Simulation results
	NIST	Best practice	Performance measure	-
7.1.4 Reporting rate >20%	GDPR	Art 33	Incident reporting	Report logs
	NIST CSF 2.0	Govern.OC-2	Engagement	-

SECCIÓN 8: COMPLIANCE

Pregunta	Regulación	Artículo	Objetivo	Evidencia
8.1.1 NIST CSF 2.0 evaluation	NIST	Standard	Framework adoption	Assessment matrix
	DORA	Art 13	Alignment	-
	NIS2	Art 13	Best practice	-
8.1.2 NIS2 readiness	NIS2	Art 17	Compliance prep	Gap analysis, roadmap
	España Law	TBD 2026	National implementation	-
8.1.3 DORA compliance	DORA	Art 11-30	Full compliance	Governance doc, RTO/RPO, testing
	BdE/CNMV	Regulatory guidance	Financial sector	-

SECCIÓN 9: AUTOMATIZACIÓN

Pregunta	Regulación	Artículo	Objetivo	Evidencia
9.1.1 Policy-as-Code	NIST CSF 2.0	Protect.PR-1	Access control automation	Policy code, deployment logs
	ISO 27001	Clause 8.3	Control implementation	-
9.1.2 Infrastructure-as-Code	NIST CSF 2.0	Protect.PR-2	Reproducible infrastructure	IaC templates, deployment history
	ISO 27001	Clause 8.2	Configuration management	-
9.2.1 Resilience testing	DORA	Art 19	Incident response testing	Test results, RTO achievement
	NIST CSF 2.0	Respond + Recover	Resilience validation	-
9.2.2-9.2.3 RTO/RPO	DORA	Art 19	Recovery objectives	Documentation, test evidence
	ISO 22301 (BCP)	Standard	Business continuity	-

CÁLCULO COMPLIANCE SCORE

Fórmula Compliance por Regulación

GDPR Compliance Score = (Qs con evidencia GDPR / Total GDPR Qs) × 100

DORA Compliance Score = (Qs con evidencia DORA / Total DORA Qs) × 100

NIS2 Compliance Score = (Qs con evidencia NIS2 / Total NIS2 Qs) × 100

REGULATORIO AGGREGATE = (GDPR + DORA + NIS2) / 3

Target Compliance

Regulación	Target Score	Timeline	Penalty
GDPR	100% (ya vigente)	Ahora	€20M o 4% revenue
DORA	100% (sector financiero)	Enero 2025	€10M o 2% revenue
NIS2	90% (grace period)	Q1-Q2 2026	€10M (essential) o €7M (important)

VALIDACIÓN EVIDENCIA

Para cada pregunta, auditor debe validar:

1. Documentación: ¿Existe documento formal?
2. Approvals: ¿Aprobado por autoridad competente?
3. Implementación: ¿Implementado en práctica, no solo paper?
4. Monitoring: ¿Se monitorea cumplimiento continuo?
5. Updates: ¿Se actualiza cuando cambia entorno?

Scoring Validación:

- **4 puntos:** Documentado + Aprobado + Implementado + Monitoreado + Actualizado
- **3 puntos:** Documentado + Aprobado + Implementado (sin monitor continuo)
- **2 puntos:** Documentado + Aprobado (pero no totalmente implementado)
- **1 punto:** Documentado informalmente
- **0 puntos:** No existe

Fin Mapeo Normativo